

Cyber CORP
Security Assessment Findings Report

Business Confidential

Date: June 3rd, 2025
Project: DC-001
Version

Copyright © TCM Security (tcm-sec.com)

Confidentiality Statement

This document is the exclusive property of Cyber Corp and X. This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both Cyber Corp and X.

Demo Corp may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

Disclaimer

A penetration test is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.

Time-limited engagements do not allow for a full evaluation of all security controls. Cyber Corp prioritized the assessment to identify the weakest security controls an attacker would exploit. Cyber Corp recommends conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

Contact Information

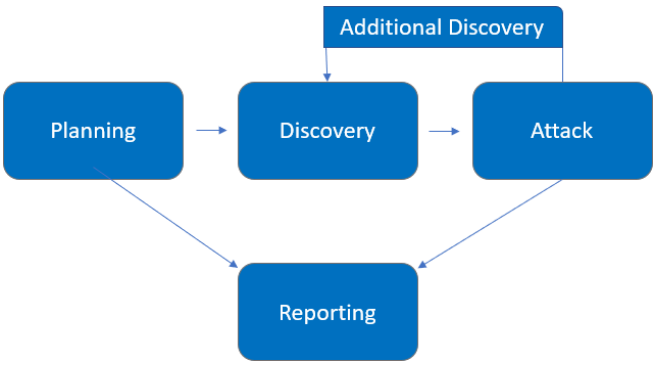
Name	Title	Contact Information
Cyber Corp		
Cyber Corp	Global Information Security Manager	Email:jsmith@cybercorp.com
Cyber Corp		
Heath Adams	Lead Penetration Tester	Email: heath@cybercorp.com

Assessment Overview

From June 3rd, 2025 to June 4th, 2025, Demo Corp engaged Cyber Corp to evaluate the security posture of its infrastructure compared to current industry best practices that included an internal network penetration test. All testing performed is based on the NIST *SP 800-115 Technical Guide to Information Security Testing and Assessment, OWASP Testing Guide (v4), and customized testing frameworks*.

Phases of penetration testing activities include the following:

- Planning – Customer goals are gathered and rules of engagement obtained.
- Discovery – Perform scanning and enumeration to identify potential vulnerabilities, weak areas, and exploits.
- Attack – Confirm potential vulnerabilities through exploitation and perform additional discovery upon new access.
- Reporting – Document all found vulnerabilities and exploits, failed attempts, and company strengths and weaknesses.



Assessment Components

Internal Penetration Test

This assessment emulates an attacker with internal network access, specifically targeting web application vulnerabilities that facilitate lateral movement and domain compromise. The engagement focuses on exploiting common web application weaknesses including authentication bypass techniques such as SQL injection in login forms and JWT tampering, insecure direct object references in API endpoints that expose unauthorized data, and server-side request forgery vulnerabilities enabling internal network pivoting. Additional testing includes cross-site scripting attacks to hijack user sessions, malicious file upload functionalities that allow webshell deployment, and insecure deserialization vulnerabilities in application servers that could lead to remote code execution. The primary objectives involve establishing initial access through these web application vulnerabilities, then progressing to credential harvesting through compromised sessions and cracked password hashes.

This access enables lateral movement to other systems, privilege escalation through misconfigured administrative interfaces, and ultimately data exfiltration via vulnerable APIs or improperly secured databases. The test simulates how web application flaws can serve as entry points for full domain compromise when combined with internal attack techniques.

Finding Severity Ratings

The following table defines levels of severity and corresponding CVSS score range that are used throughout the document to assess vulnerability and risk impact.

Severity	CVSS V3 Score Range	Definition
Critical	9.0-10.0	A01: Broken Access Control A02: Cryptographic Failures A03: Injection
High	7.0-8.9	A04: Insecure Design: A05: Security Misconfiguration
Moderate	4.0-6.9	A06: Vulnerable Components A07: Identification Failures
Low	0.1-3.9	A08:Software Integrity Failures A09: Security Logging Gaps
Informational	N/A	A10: SSRF Context-dependent

Risk Factors

Risk is measured by two factors: Likelihood and Impact:

Likelihood

Likelihood measures the potential of a vulnerability being exploited. Ratings are given based on the difficulty of the attack, the available tools, attacker skill level, and client environment.

Impact

Impact measures the potential vulnerability's effect on operations, including confidentiality, integrity, and availability of client systems and/or data, reputational harm, and financial loss.

Scope

Assessment	Details
Internal Penetration Test	172.236.8.209:5000 Web App + Hosts

Scope Exclusions

Per client request, TCMS did not perform any of the following attacks during testing:

- Denial of Service (DoS)
- Phishing/Social Engineering

All other attacks not specified above were permitted by Demo Corp.

Client Allowances

Cyber Corp provided X the following allowances:

- Internal access to network via dropbox and port allowances

Executive Summary

Cyber Corp evaluated X's internal security posture through penetration testing from June 3rd, 2025 to June 4th, 2025. The following sections provide a high-level overview of vulnerabilities discovered, successful and unsuccessful attempts, and strengths and weaknesses. An internal assessment of the web application hosted at 172.236.8.209:5000 revealed a number of critical security weaknesses that could allow an attacker to gain unauthorized access, escalate privileges, and extract sensitive information. The evaluation involved both automated and manual techniques, including traffic interception, source code inspection, and input manipulation.

The login interface was found to lack essential protections, such as anti-CSRF tokens, server-side input validation, and safeguards against brute-force attacks. These omissions allowed the login mechanism to be bypassed using common injection techniques. Additionally, the application disclosed unnecessary internal details through an animated scripting panel, revealing the use of artificial intelligence technologies. Such information can provide attackers with insight into the application's architecture and potential points of exploitation.

Following the initial compromise, further navigation led to a password reset feature that disclosed whether a username existed. By submitting commonly used names, it was possible to confirm active accounts and successfully reset the password for the administrative user. Another section of the application allowed access to user-specific notes using a PIN-based mechanism. Traffic analysis revealed exposed user data, including a hash and a username, which were then used to access another user's personal content, indicating broken access controls and weak authentication logic.

The session management approach further exacerbated the risks. Session cookies were found to be transmitted over unencrypted channels and lacked protective attributes, making them vulnerable to interception and misuse. These issues collectively demonstrate a lack of foundational security controls, particularly around authentication, authorization, and data handling.

In summary, the assessment concluded that the application suffers from several systemic flaws in its security design. Immediate corrective actions are recommended to prevent unauthorized access, protect user data, and ensure the integrity of the platform. This includes implementing secure transmission protocols, strengthening authentication workflows, and enforcing proper session handling practices throughout the application

Scoping and Time Limitations

Scoping during the engagement did not permit denial of service or social engineering across all testing components.

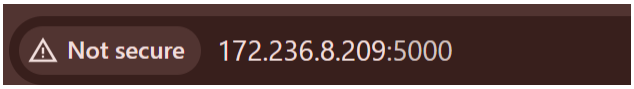
Time limitations were in place for testing. Internal network penetration testing was permitted for two (2) business days.

Technical Findings: Internal Penetration Test Findings

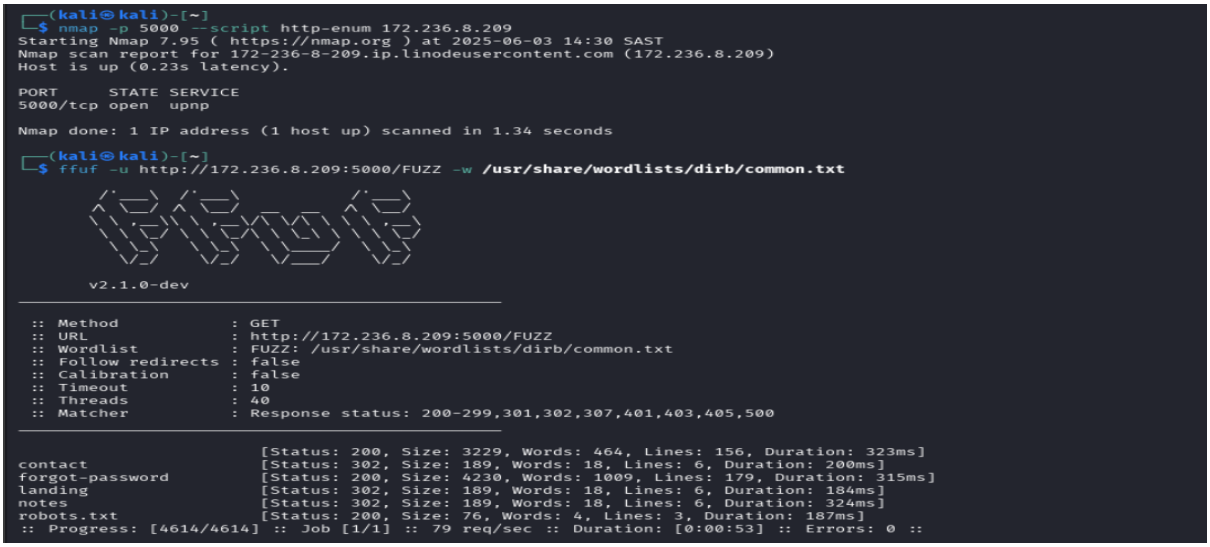
🌐 Finding WEB-001: Insecure Web Server Configuration (High)

Category	Details
Description	The target web application (172.236.8.209:5000) exhibited critical security flaws during reconnaissance: - **HTTP Protocol:** Site operates over unencrypted HTTP, allowing MITM and packet sniffing - **Exposed robots.txt:** Revealed hidden admin paths such as /user-panel/ - **Directory Busting:** Discovered unprotected endpoints: /forget-password, /notes, /api/v1/profile
Risk - Likelihood	High – Exploitable with trivial tools like curl, dirb, Burp Suite
Risk - Impact	Very High – Unencrypted traffic enables credential theft; exposed paths increase brute-force and RCE attack surfaces
Tools Used	Nmap, Fuzz, Burp Suite, Manual Inspection
References	OWASP A05:2021 (Security Misconfiguration) -
Remediation	**Enable HTTPS** with TLS 1.2/1.3 and valid certs (e.g., Let's Encrypt) - Enforce **HTTP → HTTPS redirects** - **Restrict robots.txt**: Remove or limit references to sensitive paths like /user-panel/ - Apply **IP-based restrictions** or **WAF rules** to block unauthorized access to exposed endpoints

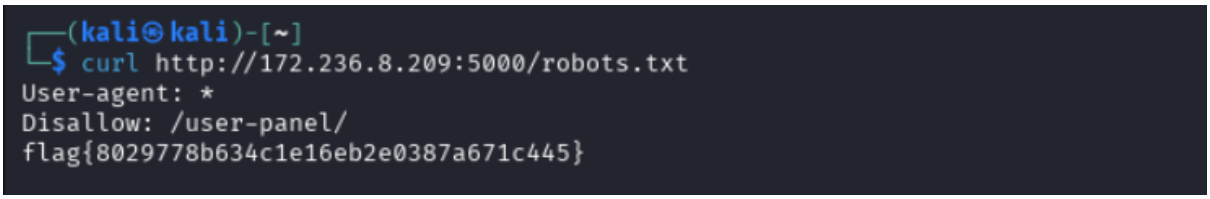
Evidence

1. 

2.


┌──(kali㉿kali)-[~]
└─$ nmap -p 5000 --script http-enum 172.236.8.209
Starting Nmap 7.95 (https://nmap.org) at 2025-06-03 14:30 SAST
Nmap scan report for 172-236-8-209.ip.linodeusercontent.com (172.236.8.209)
Host is up (0.23s latency).
PORT STATE SERVICE
5000/tcp open upnp
Nmap done: 1 IP address (1 host up) scanned in 1.34 seconds
┌──(kali㉿kali)-[~]
└─$ ffuf -u http://172.236.8.209:5000/FUZZ -w /usr/share/wordlists/dirb/common.txt
v2.1.0-dev
:: Method : GET
:: URL : http://172.236.8.209:5000/FUZZ
:: Wordlist : FUZZ: /usr/share/wordlists/dirb/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
[Status: 200, Size: 3229, Words: 464, Lines: 156, Duration: 323ms]
contact [Status: 302, Size: 189, Words: 18, Lines: 6, Duration: 200ms]
forgot-password [Status: 200, Size: 4230, Words: 1009, Lines: 179, Duration: 315ms]
landing [Status: 302, Size: 189, Words: 18, Lines: 6, Duration: 184ms]
notes [Status: 302, Size: 189, Words: 18, Lines: 6, Duration: 324ms]
robots.txt [Status: 200, Size: 76, Words: 4, Lines: 3, Duration: 187ms]
:: Progress: [4614/4614] :: Job [1/1] :: 79 req/sec :: Duration: [0:00:53] :: Errors: 0 ::

3.


┌──(kali㉿kali)-[~]
└─$ curl http://172.236.8.209:5000/robots.txt
User-agent: *
Disallow: /user-panel/
flag{8029778b634c1e16eb2e0387a671c445}

🔒 Finding WEB-002: Insecure Authentication Form (Critical)

Category	Details
Description	The exposed /user-panel login form (172.236.8.209:5000/user-panel) contains multiple high-risk flaws: - No CSRF Protection - Client-Side Validation Only - Password Field Vulnerabilities - Information Leakage (AI typing script reveals internal tech stack)
Risk - Likelihood	High – Exploitable with browser developer tools or Burp Suite
Risk - Impact	Critical – Could lead to admin account compromise via CSRF or brute-force attacks
Tools Used	Manual inspection, Burp Suite
References	OWASP A07:2021 (Identification Failures), NIST SP800-63B (Authentication Standards)
Remediation	**Immediate (24–48 hours):** 1. Add CSRF Tokens (e.g., Flask-WTF for Python)2. Enforce server-side validation (reject empty/malformed fields) **Long-Term (1–2 weeks):** 3. Add rate limiting and CAPTCHA 4. Remove or obfuscate AI typing script details

---

Evidence:

1.

```
<h4>Login to Web CTF</h4>
<form method="POST">
  <div class="input-field">
    <input id="username" name="username" type="text" class="validate" required>
    <label for="username">Username</label>
  </div>
  <div class="input-field">
    <input id="password" name="password" type="password" class="validate" required>
    <label for="password">Password</label>
  </div>
  <button type="submit" class="btn teal">Login</button>
```

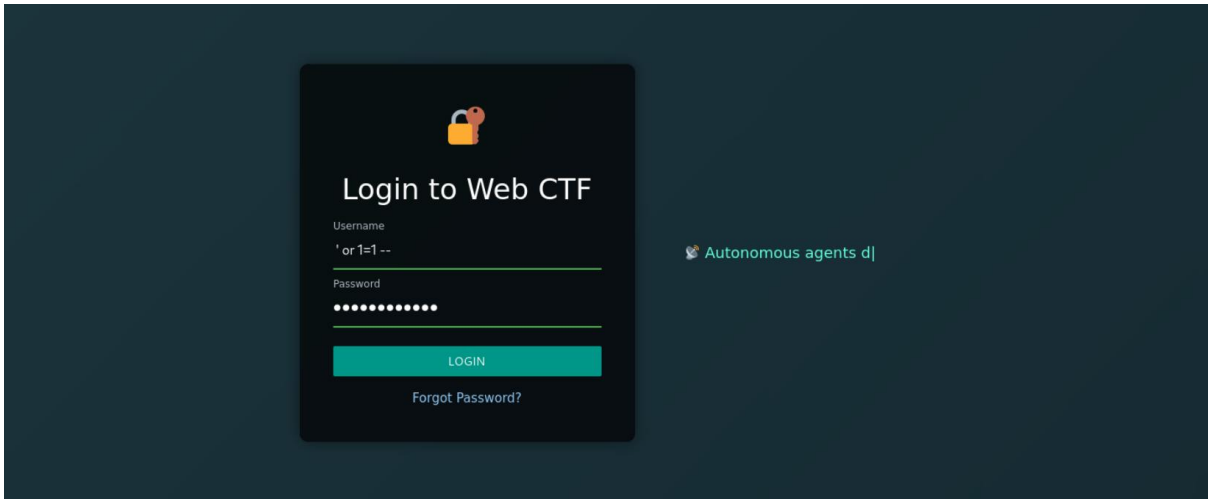
2.
```
const lines = [
  "🤖 Artificial Intelligence is revolutionizing cybersecurity...",
  "🔍 Machine learning detects threats faster than humans.",
  "🧠 Neural networks power modern intrusion detection.",
  "🛡️ AI enhances real-time incident response.",
  "📊 Pattern recognition helps prevent zero-day exploits.",
  "🛰️ Autonomous agents defend your network.",
  "🔐 Build cyber resilience with intelligent automation."
];
```

☐ Finding WEB-003: SQL Injection Authentication Bypass (Critical)

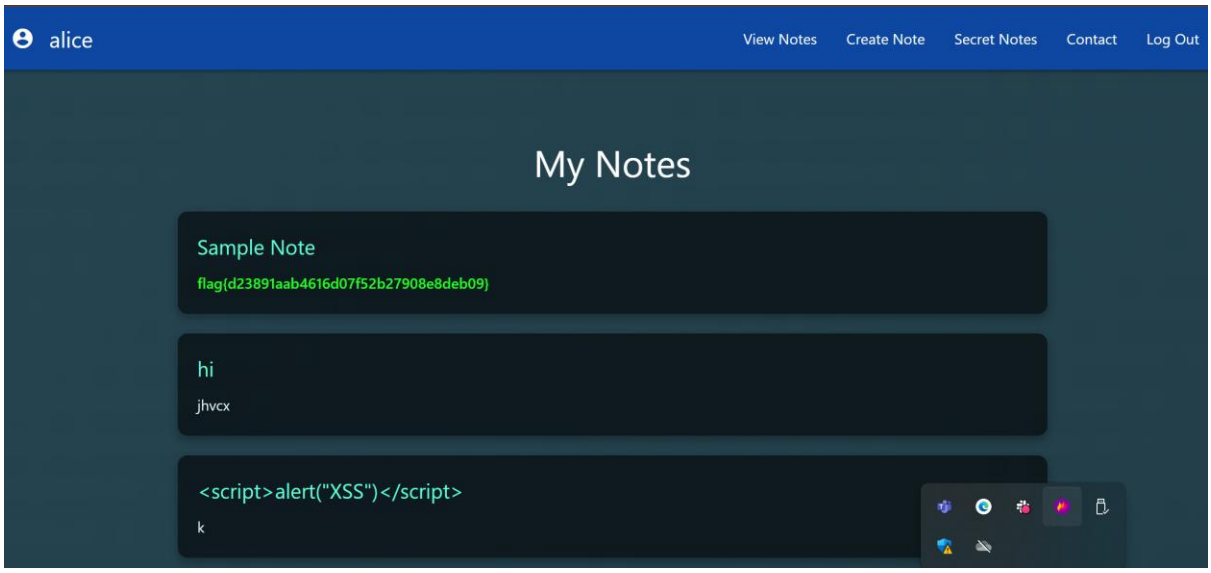
Category	Details
Description	The /user-panel login form is vulnerable to SQL injection: - **PoC:** Login succeeded with payload 'or i=1-- - **Impact:** Unauthorized user access - **DB Fingerprinting:** Likely MySQL/MariaDB due to syntax and behavior
Risk - Likelihood	Very High – Exploitable with curl or browser dev tools
Risk - Impact	Critical – Leads to privilege escalation, data exfiltration, or even RCE via stacked queries
Tools Used	Manual testing ,
References	OWASP A01:2021 (Injection), CWE-89
Remediation	**Immediate (within 24h):** 1. Use parameterized queries (e.g., SQLAlchemy bind parameters) 2. Implement input sanitization and allowlists

Evidence:

1.


Login to Web CTF
Username
' or 1=1 --
Password
LOGIN
Forgot Password?
Autonomous agents d|

2.

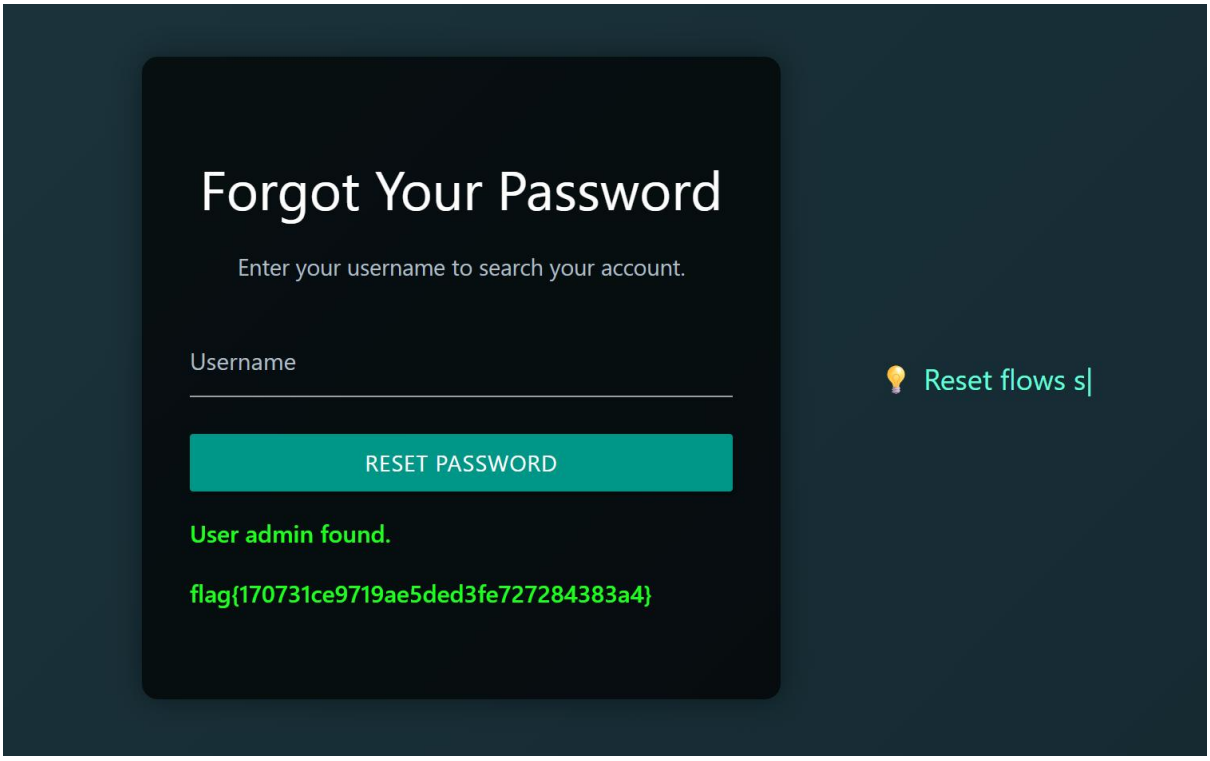

alice
View Notes
Create Note
Secret Notes
Contact
Log Out
My Notes
Sample Note
flag{d23891aab4616d07f52b27908e8deb09}
hi
jhvcx
<script>alert("XSS")</script>
k

🔐 Finding WEB-004: Insecure Password Reset & Username Enumeration (Critical)

Category	Details
Description	During directory enumeration, the endpoint /forg returned a 200 OK, revealing access to a forgotten password reset page. Manual souot-passwordrce code inspection revealed that the application discloses whether a username exists in the system. - **Information Disclosure:** The reset form confirms valid usernames with specific messages. - **Weak Reset Controls:** A reset was triggered by submitting the username 'admin', indicating poor verification logic and lack of secure token mechanisms.
Risk - Likelihood	Low – Exploitable manually using common usernames (e.g., admin, user1)
Risk - Impact	Critical – Username enumeration leads to targeted attacks; insecure resets can enable full account takeover
Tools Used	Browser, Manual Source Inspection
References	OWASP A07:2021 (Identification and Authentication Failures), OWASP A04:2021 (Insecure Design)
Remediation	- Replace specific feedback like "username does not exist" with a **generic response** for both valid and invalid entries. - Implement **secure reset workflows** using one-time tokens sent via email/SMS - Rate-limit reset attempts and enforce CAPTCHA - Audit password reset logic to require identity validation before actioning a reset

Evidence:

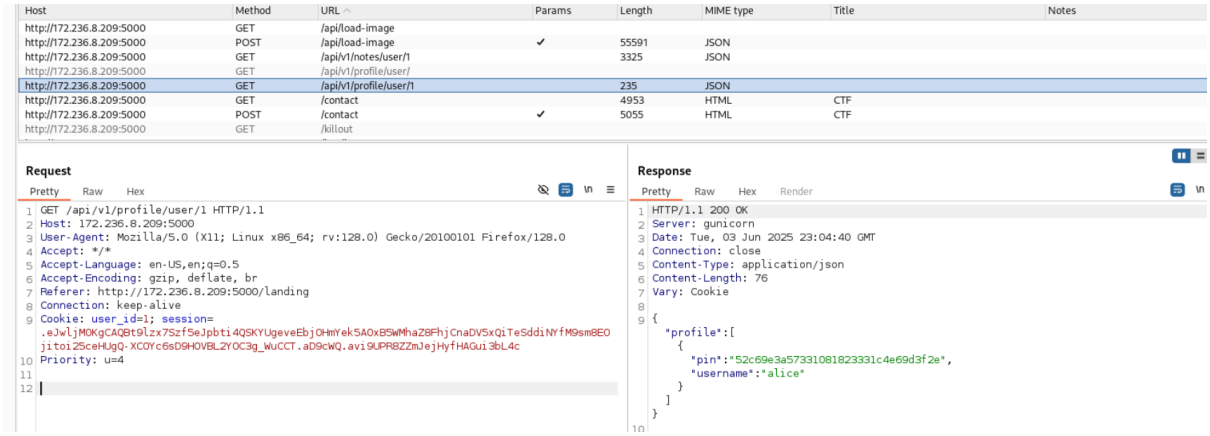

Not secure
172.236.8.209:5000/forgot-password


Forgot Your Password
Enter your username to search your account.
Username
RESET PASSWORD
User admin found.
flag{170731ce9719ae5ded3fe727284383a4}
Reset flows s

📝 Finding WEB-005: Insecure Note Access via PIN Enumeration and Hash Disclosure (Critical)

Category	Details
Description	After logging in via SQL injection, manual navigation revealed that note access required a **PIN**. While inspecting traffic with a proxy (Burp Suite), the response contained both a **hash** and **username: Alice**. The hash was cracked using CrackStation, revealing Alice's PIN. This allowed unauthorized access to her personal notes. - **Hash Exposure:** Sensitive authentication material was exposed in traffic. - **Weak Authentication Mechanism:** The application relied on a PIN alone without session validation or binding to user identity.
Risk - Likelihood	Very High – Easily exploitable with basic proxy tools and hash cracking platforms
Risk - Impact	Critical – Leads to unauthorized access to another user's private information (Alice's notes), violating confidentiality and access control
Tools Used	Burp Suite, Repeater, CrackStation
References	OWASP A01:2021 (Broken Access Control), CWE-522 (Insufficiently Protected Credentials), CWE-200 (Information Exposure)
Remediation	- Remove sensitive information (e.g., hashes, usernames) from client-side responses - Enforce session-based access checks to prevent IDOR (Insecure Direct Object References) - Replace PIN-based authentication with secure tokens tied to authenticated sessions - Monitor logs for suspicious access and reset exposed user credentials

Evidence:



Host	Method	URL	Params	Length	MIME type	Title	Notes
http://172.236.8.209:5000	GET	/api/load-image					
http://172.236.8.209:5000	POST	/api/load-image	✓	55591	JSON		
http://172.236.8.209:5000	GET	/api/v1/notes/user/1		3325	JSON		
http://172.236.8.209:5000	GET	/api/v1/profile/user/					
http://172.236.8.209:5000	GET	/api/v1/profile/user/1		235	JSON		
http://172.236.8.209:5000	GET	/contact		4953	HTML	CTF	
http://172.236.8.209:5000	POST	/contact	✓	5055	HTML	CTF	
http://172.236.8.209:5000	GET	/killout					

Request

Pretty Raw Hex

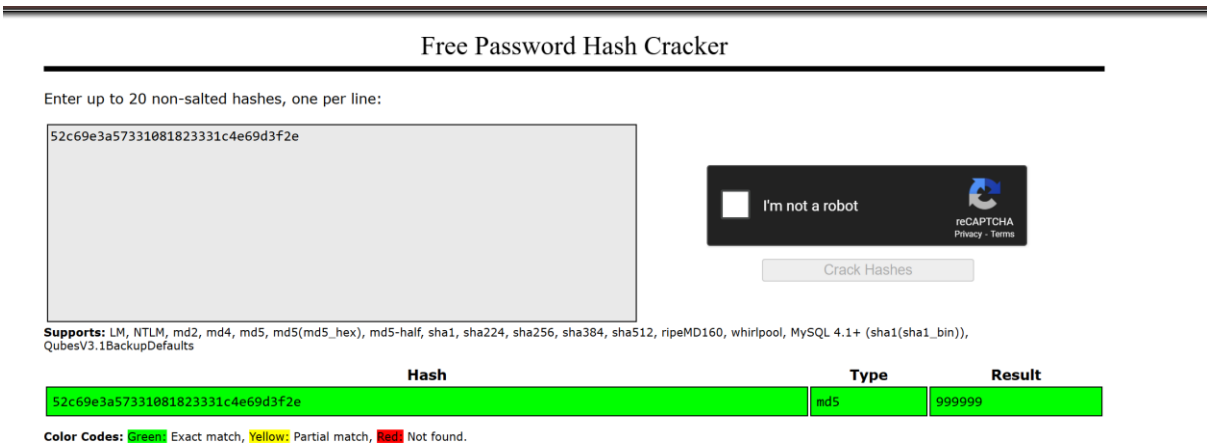
```
GET /api/v1/profile/user/1 HTTP/1.1
Host: 172.236.8.209:5000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://172.236.8.209:5000/landing
Connection: keep-alive
Cookie: user_id=1; session=
.eJwljMOKgCAQBt9lzx7Szf5eJpbti4QSKYUgeveEbjOHmYek5AOxB5WMhaZ8FhjCnaDV5xQiTeSddiNYfM9sm8EO
jitoi25ceHUgQ-XCOYc6sD9HOVBL2YOC3g_WuCCT.aD9cWQ.avi9UPR8ZZmJejHyfHAGui3bL4c
Priority: u=4
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Server: gunicorn
Date: Tue, 03 Jun 2025 23:04:40 GMT
Connection: close
Content-Type: application/json
Content-Length: 76
Vary: Cookie

{
  "profile":[
    {
      "pin":"52c69e3a57331081823331c4e69d3f2e",
      "username":"alice"
    }
  ]
}
```



Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

52c69e3a57331081823331c4e69d3f2e

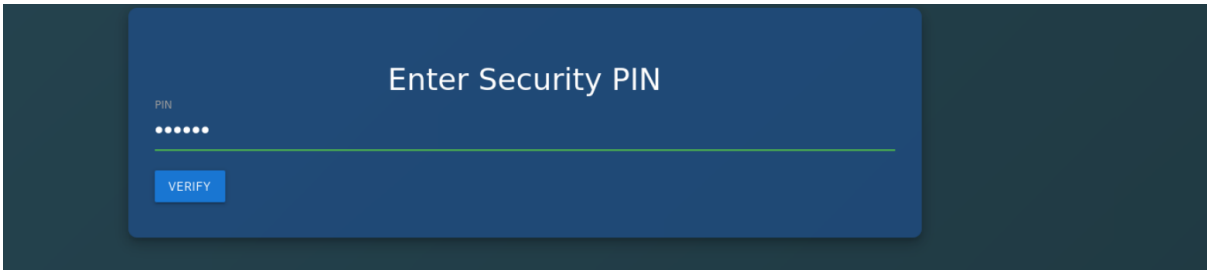
I'm not a robot reCAPTCHA Privacy - Terms

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
52c69e3a57331081823331c4e69d3f2e	md5	999999

Color Codes: Green: Exact match, Yellow: Partial match, Red: Not found.

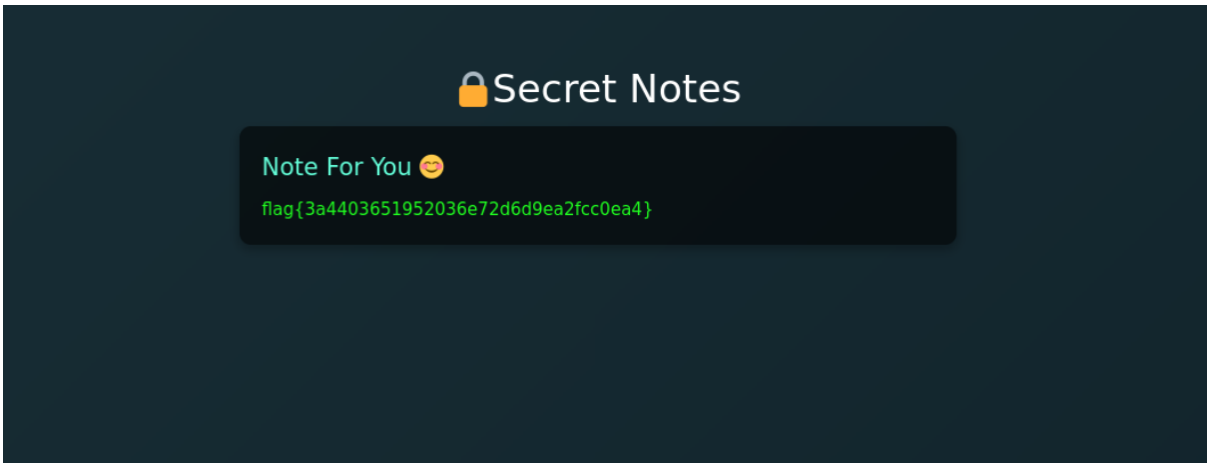


Enter Security PIN

PIN

••••••

VERIFY



.

Additional Enumeration and Reports

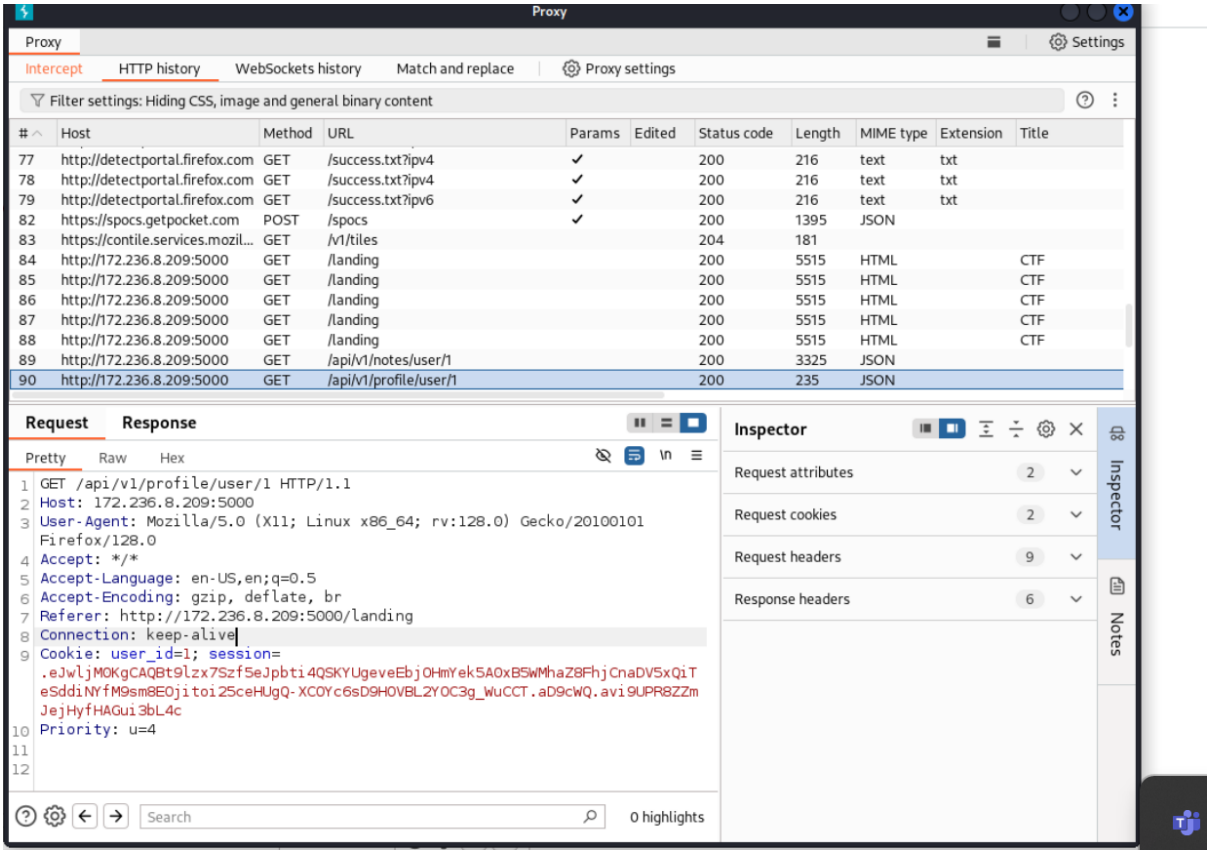
🍪 Finding WEB-006: Insecure Cookie Handling and Exposure (Critical)

Category	Details
Description	During traffic interception, a cookie was captured in cleartext. This indicates the application is likely serving cookies over **unencrypted HTTP**, exposing them to **Man-in-the-Middle (MitM)** attacks. Upon further analysis, the cookie also lacked key security flags: - **Secure flag** missing: Cookie transmitted over HTTP. - **HttpOnly flag** missing: Cookie accessible via JavaScript, increasing **XSS** risk. - **SameSite attribute** misconfigured or missing: Vulnerable to **CSRF**.
Risk - Likelihood	Very High – Passive sniffing or interception tools (e.g., Burp, Wireshark) can easily capture and replay sessions
Risk - Impact	Critical – A stolen session cookie could allow full session hijacking and unauthorized access to user accounts
Tools Used	Burp Suite, Browser Developer Tools
References	OWASP A05:2021 (Security Misconfiguration), OWASP A07:2021 (Identification and Authentication Failures), CWE-614: Sensitive Cookie in HTTP Request

Remediation:

- Enforce HTTPS site-wide and mark all session cookies with the Secure flag
- Use HttpOnly to prevent client-side scripts from accessing cookies
- Set SameSite=Strict or SameSite=Lax to prevent CSRF
- Regularly rotate session tokens and invalidate sessions upon logout or inactivit

Evidence:



Last Page

Copyright © TCM Security (tcm-sec.com)